



Email Header Analysis

When investigating **phishing, spam, or malicious emails**, SOC analysts don't just look at the body of the email — they analyze the **email header**.



The **email header** contains **hidden metadata** (routing info, sender details, technical info) that helps analysts **trace the source** and detect **spoofing or compromise**.

◆ What is an Email Header?

- A **technical part of the email** that shows:
 - From where the email originated
 - Which servers it passed through
 - Whether it is legitimate or spoofed
 - Security checks like SPF/DKIM/DMARC results



Usually **not visible** in email clients (like Gmail, Outlook) unless you "View Original / Show Source."

◆ Key Fields in an Email Header

Here are the **most important fields SOC analysts focus on**:

1. From

- Shows who sent the email.
- ⚠ Can be spoofed easily.

2. Return-Path

- Actual bounce-back address.
- Often different from "From" in spoofed emails.

3. Received (most important)

- Shows the **path the email took** (like hops in traceroute).
- The **bottom-most "Received" line** usually reveals the **real sending IP**.

4. Message-ID

- Unique identifier for the email.
- Can reveal the domain that generated the email (legit or fake).

5. Reply-To

- If different from "From," may indicate fraud (phishing trick).

6. SPF, DKIM, DMARC Results

- Shows whether the sending domain passed these security checks.

7. X-Originating-IP / X-Mailer

- Extra fields added by some servers.
- Can reveal original sender's IP or email client.

◆ Example of a Real Email Header (simplified)

Received: from mail.evilm.com (123.45.67.89) by mx.google.com

Return-Path: <attacker@evil.com>

From: "Bank Support" <support@fakebank.com>

Reply-To: <scammer@evilmail.com>

Message-ID: <abc123@mail.evilm.com>

Authentication-Results: spf=fail; dkim=fail; dmarc=fail

👉 Analysis:

- 123.45.67.89 = real sending IP (can check reputation in VirusTotal, AbuseIPDB).
- "From" looks like a bank, but **SPF/DKIM/DMARC = fail** → spoofed.
- Reply-To is a **different domain** → phishing.

◆ Steps for SOC Email Header Analysis

1. Extract full headers (from Outlook, Gmail, Thunderbird, etc.).
2. Look at **Received lines** (find origin IP).
3. Check **SPF, DKIM, DMARC** results.
4. Verify **Message-ID domain** matches sender's domain.
5. Inspect **Reply-To / Return-Path** mismatches.
6. Run IP/domain against threat intelligence tools (VirusTotal, MISP, AbuseIPDB).
7. Document findings for incident response.

◆ Why it's Important for SOC Analysts

- Identifies **phishing attacks**
- Detects **spoofed domains**
- Helps in **forensic investigation**
- Provides **IoCs (Indicators of Compromise)** for threat hunting

✅ In short:

Email header analysis = forensic investigation of hidden technical fields inside an email to detect fraud, phishing, or malicious activity.